

CASE FILE CA-ETI-01

EMAIL THREAT INVESTIGATION & ANALYSIS

Investigation Report

Prepared for: Solvex Industries Pvt. Ltd. — Finance Department

Prepared by: Taraka Divya Ketha

Mailbox Owner: Mr. Aditya Rao, Senior Finance Executive

Investigating Analyst: Cyber Security & Ethical Hacking Intern, Cryptonic Area Internship Program

Date of Report: 15 Aug 2026

CONFIDENTIAL — Internal Investigation Use Only

Executive Summary

Thirteen emails recovered from the mailbox of Mr. Aditya Rao (Senior Finance Executive, Solvex Industries Pvt. Ltd.) were analyzed following a finance-team report of unusual activity and a suspected fraud attempt. Each message was examined for sender authenticity (From / Reply-To / Return-Path alignment), SPF / DKIM / DMARC results, originating infrastructure, encryption, message content, and any links or attachments.

Of the 13 emails reviewed, 5 were classified SAFE, 6 were classified SUSPICIOUS, and 2 were classified MEDIUM RISK. In total, 8 of the 13 emails (over 60%) represent some form of social-engineering, credential-phishing, malware-delivery, or financial-fraud attempt.

Key findings:

- A clear pattern of Business Email Compromise (BEC) is present across multiple emails — a fake 'Managing Director' wire-transfer request, a fake 'CFO' gift-card request, and a vendor invoice with a bank-account-change request — indicating the mailbox and/or its known contacts were specifically targeted for finance fraud, not just generic spam.
- Two credential-harvesting phishing emails impersonated IT Helpdesk and Microsoft using typo squatted domains (solvex-industries-helpdesk.com and micros0ft-online.com).
- One email delivered a macro-enabled Word document (.docm) designed to execute malware if macros were enabled, and one delivered a ZIP attachment from an unsolicited recruiter.
- One advance-fee lottery scam and one vendor-impersonation payment-redirection attempt were also identified.
- Five emails were verified as genuine, low-risk internal or vendor communications with consistent, fully-authenticated headers and no requests for credentials, payments, or unusual actions.

Given the volume and sophistication of targeted fraud attempts (particularly the BEC/wire-transfer and gift-card scams referencing real internal names), this mailbox should be treated as a priority target of an active social-engineering campaign against Solvex Industries' finance function. Immediate staff awareness reinforcement and out-of-band verification procedures for any payment or bank-detail change request are strongly recommended.

Classification Overview

SAFE: 5 | SUSPICIOUS: 6 | MEDIUM RISK: 2 | Total emails reviewed: 13

#	Subject	Classification	Primary Threat Type
1	Password Expiry Reminder – Action Needed Within 5 Days	SAFE	None (genuine)
2	URGENT: Your Mailbox Storage is FULL – Verify Now to Avoid Suspension	SUSPICIOUS	Credential phishing (IT Helpdesk spoof)
3	Invoice SI-4471 & Updated Bank Details for Future Payments	MEDIUM RISK	Vendor payment redirection (BEC)
4	Revised Leave & Work-From-Home Policy – Effective 15 July 2026	SAFE	None (genuine)
5	Confidential – Immediate Wire Transfer Required (Time Sensitive)	SUSPICIOUS	CEO fraud / wire-transfer BEC
6	'Q1_Vendor_Compliance_Report.xlsx' has been shared with you	SAFE	None (genuine)
7	Unusual sign-in activity detected on your	SUSPICIOUS	Credential phishing

#	Subject	Classification	Primary Threat Type
	Microsoft account		(Microsoft spoof)
8	Exciting Career Opportunity – Senior Finance Role (Immediate Response Needed)	MEDIUM RISK	Recruitment scam / PII & malware
9	Your TallyPrime Cloud Subscription Renewal Invoice – INV-88213	SAFE	None (genuine)
10	CONGRATULATIONS!!! YOU HAVE WON USD 1,000,000 IN THE INTERNATIONAL EMAIL LOTTERY	SUSPICIOUS	Advance-fee lottery scam
11	Quick request before my flight	SUSPICIOUS	Gift-card BEC scam
12	Reminder: Mandatory Security Awareness Training – Due This Friday	SAFE	None (genuine)
13	Pending Invoice – Please Review & Process on Priority	SUSPICIOUS	Malware delivery (macro document)

Email-by-Email Analysis

Email 1 of 13 — Password Expiry Reminder – Action Needed Within 5 Days

Classification: **SAFE**

From	IT Helpdesk – Solvex Industries <ithelpdesk@solvexindustries.com>
Reply-To	ithelpdesk@solvexindustries.com
Return-Path	ithelpdesk@solvexindustries.com
Received From	mail.solvexindustries.com (192.168.14.22) – internal mail server
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.3)

Reasoning / Evidence

- Sender, Reply-To and Return-Path all match the legitimate internal domain solvexindustries.com.
- SPF, DKIM and DMARC all pass; message travelled entirely over the internal, TLS-encrypted mail server (private 192.168.x.x address).
- No embedded link or attachment; the message even reminds staff never to share passwords with anyone, including IT — consistent with genuine helpdesk practice.
- Tone is informational and routine (90-day rotation policy), with no urgency, threats, or unusual requests.

From	IT Helpdesk – Solvex Industries <ithelpdesk@solvexindustries.com>
Reply-To	ithelpdesk@solvexindustries.com
Return-Path	ithelpdesk@solvexindustries.com
To	aditya.rao@solvexindustries.com
Cc	—
Bcc	—
Date & Time	03 July 2026, 10:12 AM IST
Received From	mail.solvexindustries.com (192.168.14.22)
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	Yes (TLS 1.3)

Exhibit 1 — Header snapshot. Sender, Reply-To, and Return-Path all match solvexindustries.com; SPF, DKIM, and DMARC all pass on the genuine internal mail server.

Assessment

No malicious action is possible from this email as written — it contains no credential-harvesting link or attachment.

Recommended Action

No action required beyond normal password rotation through the internal IT Service Portal. Retain as a baseline example of what a genuine internal notice looks like.

Email 2 of 13 — URGENT: Your Mailbox Storage is FULL – Verify Now to Avoid Suspension**Classification: SUSPICIOUS**

From	IT Support Desk <support@solvex-industries-helpdesk.com>
Reply-To	recovery-team@mail-secure-verify.net
Return-Path	bounce@mail-secure-verify.net
Received From	unknown-host-193.41.77.108.static-cloud.ru (193.41.77.108)
SPF	Fail
DKIM	Fail
DMARC	Fail (Reject policy overridden)
Encryption (TLS)	No (Unencrypted)

Reasoning / Evidence

- Sender domain solvex-industries-helpdesk.com is a lookalike of the real solvexindustries.com — it inserts a hyphen and an extra word to mimic IT support.
- Reply-To (mail-secure-verify.net) and Return-Path (a different domain again) do not match the From domain — three different domains across one message is a strong spoofing indicator.
- SPF, DKIM and DMARC all fail and the DMARC reject policy was overridden, meaning the receiving system let through a message it should have blocked.
- Originating IP resolves to a Russian cloud/VPS host, not Solvex's mail infrastructure, and the connection was unencrypted.
- The message was Bcc'd to a mass distribution list (allstaff-list223), indicating a bulk phishing blast rather than a targeted IT notice.
- Classic urgency and fear tactics: 'FULL', 'IMMEDIATE', 'final notice', a 24-hour countdown, and a threat of permanent data loss to pressure quick, unthinking action.
- The embedded link domain (solvex-industries-helpdesk.verify-account-secure.com) is a typo squat built to imitate the company name while being hosted on unrelated infrastructure.

From	IT Support Desk <support@solvex-industries-helpdesk.com>
Reply-To	recovery-team@mail-secure-verify.net
Return-Path	bounce@mail-secure-verify.net
To	aditya.rao@solvexindustries.com
Cc	—
Bcc	allstaff-list223@solvex-industries-helpdesk.com
Date & Time	05 July 2026, 11:47 PM IST
Received From	unknown-host-193.41.77.108.static-cloud.ru (193.41.77.108)
SPF	Fail
DKIM	Fail
DMARC	Fail (Reject policy overridden)
Encryption	No (Unencrypted)

Exhibit 2a — Header snapshot. From, Reply-To, and Return-Path resolve to three different domains; SPF/DKIM/DMARC all fail and the message arrived unencrypted from a Russian cloud host, Bcc'd to a mass distribution list.

EMAIL BODY

Dear User,

Your mailbox has exceeded its allocated storage limit of 5GB. As per policy, mailboxes exceeding this limit for more than 24 hours will be automatically suspended and all incoming mail will be permanently rejected.

To avoid suspension of your account, you are required to verify your identity **IMMEDIATELY** by clicking the secure link below and **confirming your login credentials**. This process takes less than 2 minutes.

Failure to verify within 24 hours will result in permanent loss of access to your mailbox and all stored data. This is a **final notice**.

Thank you for your prompt action.

IT Support Team

EMBEDDED LINK DETECTED

<http://solvex-industries-helpdesk.verify-account-secure.com/mailbox/confirm?user=aditya.rao>

Exhibit 2b — Email body. Urgency and fear language ('IMMEDIATELY', 'final notice') and the credential-harvesting link are highlighted directly in the message

What Could Happen

Clicking the link would lead to a fake Outlook/webmail login page designed to harvest Aditya's real email credentials. Once captured, attackers could gain full access to his mailbox — reading finance correspondence, resetting passwords on connected systems, and using the compromised account to send further BEC (business email compromise) attacks to colleagues, vendors, or banks.

Recommended Action

Do not click the link or enter credentials. Report the email to IT Security as phishing, delete it, and if credentials were ever entered on a similar past email, force an immediate password reset and check mailbox forwarding/rules for tampering. Block the sending domain and originating IP at the email gateway.

Email 3 of 13 — Invoice SI-4471 & Updated Bank Details for Future Payments

Classification: **MEDIUM RISK**

From	Ramesh Kulkarni – Accounts, Apex Steel Traders <ramesh.kulkarni@apex-steeltraders.co>
Reply-To	accounts.payments@apexsteel-billing.com
Return-Path	ramesh.kulkarni@apex-steeltraders.co
Received From	mail.apex-steeltraders.co (103.22.8.190)
SPF	Pass (for apex-steeltraders.co)
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.2)

Reasoning / Evidence

- Authentication (SPF/DKIM/DMARC) passes for the sending domain apex-steeltraders.co, so this is not an obvious spoof — the mail genuinely originates from that domain's infrastructure.
- However, the Reply-To address (accounts.payments@apexsteel-billing.com) belongs to a completely different, look-alike domain from the From address — any reply would leave the legitimate vendor domain entirely, a hallmark of vendor email compromise (VEC) or a lookalike accomplice domain.
- The core request — 'our current account has been temporarily restricted, pay the NEW account instead' — is the single most common pretext used in invoice/vendor payment fraud.
- Artificial urgency is present ('please confirm once the transfer has been initiated', quarter-close deadline) to discourage the recipient from independently verifying the change.
- A legitimate vendor changing bank details is unusual on its own and should always be verified out-of-band, regardless of how clean the headers look.

From	Ramesh Kulkarni – Accounts, Apex Steel Traders <ramesh.kulkarni@apex-steeltraders.co>
Reply-To	accounts.payments@apexsteel-billing.com
Return-Path	ramesh.kulkarni@apex-steeltraders.co
To	aditya.rao@solvexindustries.com
Cc	priya.menon@solvexindustries.com
Bcc	—
Date & Time	07 July 2026, 3:28 PM IST
Received From	mail.apex-steeltraders.co (103.22.8.190)
SPF	Pass (for apex-steeltraders.co)
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.2)

Exhibit 3a — Header snapshot.

Reply-To (apexsteel-billing.com) does not match the From/Return-Path domain (apex-steeltraders.co), even though SPF/DKIM/DMARC pass for the sender's own domain.

EMAIL BODY

Dear Aditya,

Please find attached Invoice SI-4471 for the steel coil consignment supplied to your Nagpur unit last month, amounting to Rs. 4,85,600/-.

As part of our internal banking audit, our current account has been temporarily restricted. Kindly note that all payments from this point forward should be made to our NEW account, details of which are mentioned in the attached invoice, and NOT our previously shared account. This change is effective immediately.

We would appreciate it if this payment could be processed on priority, as our finance team needs to close this quarter's books by the 10th. Please confirm once the transfer has been initiated so we can update our records.

Regards,

Ramesh Kulkarni

Accounts Department, Apex Steel Traders

 **Invoice_SI-4471_Apex_Steel.pdf**
PDFDocument • 812KB

Exhibit 3b — Email body and attachment. The invoice attachment is where the fraudulent 'new' bank account details actually live — always verify by phone before acting on it.

What Could Happen

If the finance team pays the 'new' account without verification, the funds (Rs. 4,85,600) go directly to an attacker-controlled account — either because the vendor's real mailbox was compromised, or because this is a look-alike domain impersonating the vendor. The money is typically unrecoverable once transferred internationally or moved through mule accounts.

Recommended Action

Do NOT update payment details based on this email alone. Call Apex Steel Traders on a previously known, independently verified phone number (not one provided in this email) to confirm the bank account change verbally. Compare the Reply-To domain against past correspondence with this vendor. Escalate to finance leadership and treat as a possible vendor account compromise until confirmed otherwise.

Email 4 of 13 — Revised Leave & Work-From-Home Policy – Effective 15 July 2026

Classification: **SAFE**

From	Human Resources – Solvex Industries <hr@solvexindustries.com>
Reply-To	hr@solvexindustries.com
Return-Path	hr@solvexindustries.com
Received From	mail.solvexindustries.com (192.168.14.19) – internal mail server
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.3)

Reasoning / Evidence

- From, Reply-To and Return-Path are all the legitimate internal HR address; full authentication passes and the message is encrypted.
- Sent to all-employees@solvexindustries.com, a normal internal broadcast pattern, not a targeted or Bcc'd blast to an external list.
- Content references a previously announced town hall and points staff to the internal HR Portal rather than an external or shortened link.
- No urgency, threats, or requests for credentials, payments, or personal data.

From	Human Resources – Solvex Industries - hr@solvexindustries.com
Reply-To	hr@solvexindustries.com
Return-Path	hr@solvexindustries.com
To	all-employees@solvexindustries.com
Cc	—
Bcc	—
Date & Time	08 July 2026, 9:05 AM IST
Received From	mail.solvexindustries.com (192.168.14.19)
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	Yes (TLS 1.3)

Exhibit 4 — Header snapshot. Consistent internal HR sender across From/Reply-To/Return-Path/To; SPF, DKIM, and DMARC all pass.

Assessment

No malicious outcome possible from this email as written.

Recommended Action

No action required. Employees can review the policy on the internal HR Portal as instructed.

Email 5 of 13 — Confidential – Immediate Wire Transfer Required (Time Sensitive)**Classification: SUSPICIOUS**

From	Rajeev Malhotra (Managing Director) <rajeev.malhotra.md@gmail-corpmail.com>
Reply-To	rajeev.malhotra.md@gmail-corpmail.com
Return-Path	rajeev.malhotra.md@gmail-corpmail.com
Received From	smtp-relay-88.freemailhost.io (45.137.22.9, Netherlands)
SPF	None (no SPF record)
DKIM	None
DMARC	None
Encryption (TLS)	No

Reasoning / Evidence

- The domain gmail-corpmail.com is not Solvex's domain and is not actually Gmail — it is crafted to look like a corporate/Google-hosted address to a hurried reader.
- No SPF, DKIM or DMARC records exist at all for the sending domain, and the message travelled unencrypted through a free/anonymous mail relay in the Netherlands — nothing about the infrastructure matches a real Managing Director's corporate mail.
- Textbook CEO Fraud / Business Email Compromise (BEC) social engineering: claims of unavailability ('in a board meeting, cannot take calls'), authority (MD title), urgency ('today', 'within the next hour'), secrecy ('do not discuss with Priya or Accounts'), and isolation from normal verification channels.
- Deliberately withholds the beneficiary bank details until a follow-up email — a tactic to get the target to commit to compliance before the risky detail (the destination account) is even shared.
- Requests bypass of normal payment controls (dual approval, Accounts team involvement) which any real MD-authorized transfer would go through.

From	Rajeev Malhotra (Managing Director) - rajeev.malhotra.md@gmail-corpmail.com>
Reply-To	rajeev.malhotra.md@gmail-corpmail.com
Return-Path	rajeev.malhotra.md@gmail-corpmail.com
To	aditya.rao@solvexindustries.com
Cc	—
Bcc	—
Date & Time	09 July 2026, 1:14 PM IST
Received From	smtp-relay-88.freemailhost.io (45.137.22.9, Netherlands)
SPF	None (domain has no SPF record)
DKIM	None
DMARC	None
Encryption	No

Exhibit 5a — Header snapshot. Sender domain is not solvexindustries.com; no SPF/DKIM/DMARC records exist at all, and the message arrived unencrypted through an anonymous relay in the Netherlands.

EMAIL BODY

Aditya,

I'm currently in a board meeting with our overseas investors and cannot take calls right now. I need you to process an urgent international wire transfer of USD 18,500 to close a confidential acquisition deal today. This is extremely time sensitive and must be kept strictly between us until I announce it to the board.

I will send the beneficiary bank details in my next email. Please confirm you can initiate this within the next hour and let me know once done. Do not discuss this with Priya or anyone in Accounts for now — I want to keep this quiet until the deal is signed.

I'm counting on you for this one. Talk soon.

Rajeev

Exhibit 5b — Email body. Authority, secrecy, and urgency cues ('cannot take calls', 'keep this quiet', 'within the next hour') are highlighted — classic CEO-fraud framing.

What Could Happen

If Aditya agreed and later received 'beneficiary details', Solvex would wire USD 18,500 directly to an attacker-controlled account with no involvement of the finance/accounts control process, and by the time it was discovered the funds would likely already be moved offshore and unrecoverable.

Recommended Action

Do not reply or act on the request. Independently verify by calling Rajeev Malhotra on his known company mobile number (not any number in the email) or confirming in person/via a separate verified channel. Report to IT Security and Finance leadership immediately, and remind staffs that no genuine executive request will ask to bypass Accounts or normal approval workflow.

Email 6 of 13 — 'Q1_Vendor_Compliance_Report.xlsx' has been shared with you

Classification: **SAFE**

From	Google Drive <drive-shares-noreply@google.com>
Reply-To	drive-shares-noreply@google.com
Return-Path	drive-shares-noreply@google.com
Received From	mail-sor-f89.google.com (209.85.220.89) – genuine Google mail infrastructure
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.3)

Reasoning / Evidence

- Sent from Google's own authenticated infrastructure (google.com) with SPF/DKIM/DMARC all passing — this is not a spoofed domain.
- The notification names a real, known colleague (priya.menon@solvexindustries.com) as the sharer and references a plausible, specific business context (today's finance sync, Friday's audit call).
- The link points to a genuine docs.google.com URL rather than a lookalike or shortened domain.
- No urgency, threats, or requests for credentials — a routine collaboration notification.

HEADER & TECHNICAL SNAPSHOT

From	Google Drive <drive-shares-noreply@google.com>
Reply-To	drive-shares-noreply@google.com
Return-Path	drive-shares-noreply@google.com
To	aditya.rao@solvexindustries.com
Cc	—
Bcc	—
Date & Time	09 July 2026, 6:40 PM IST
Received From	mail-sor-f89.google.com (209.85.220.89)
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.3)

Exhibit 6a — Header snapshot. Genuine google.com sending infrastructure; SPF, DKIM, and DMARC all pass.

EMAIL BODY

priya.menon@solvexindustries.com shared a file with you

Q1_Vendor_Compliance_Report.xlsx

Priya added a note: "Hi Aditya, sharing the vendor compliance sheet we discussed in today's finance sync. Can you review the highlighted rows before Friday's audit call? Thanks!"

Open in Google Sheets

You are receiving this email because someone shared a file or folder located in Google Drive with you. Google Drive is a place to keep and share all your stuff, photos, stories, designs, drawings, recordings, videos — whatever.

EMBEDDED LINK DETECTED

<https://docs.google.com/spreadsheets/d/1kQ3z-example-fileid-9f2/edit?usp=sharing>

Exhibit 6b — Email body. The embedded link resolves to a genuine docs.google.com URL, and the note references a real, known colleague and meeting context

Assessment

Low risk as received. The main residual risk in this pattern generally is a compromised colleague account being used to distribute a booby-trapped file — headers alone cannot fully rule that out.

Recommended Action

Safe to open, but as good practice confirm with Priya Menon directly (in person, chat, or phone) that she did in fact share this file before entering any sensitive information into it, since Google-hosted file-share notifications can also follow if a colleague's own account is compromised.

Email 7 of 13 — Unusual sign-in activity detected on your Microsoft account

Classification: **SUSPICIOUS**

From	Microsoft account team <security-noreply@micros0ft-online.com>
Reply-To	no-reply@micros0ft-online.com
Return-Path	bounce@micros0ft-online.com
Received From	host-77-91-134-6.vpn-exit.net (77.91.134.6, unknown origin)
SPF	Fail
DKIM	Fail
DMARC	Fail
Encryption (TLS)	No

Reasoning / Evidence

- The domain micros0ft-online.com uses a zero in place of the letter 'o' — a classic typo squat designed to pass a quick visual glance.
- SPF, DKIM and DMARC all fail, and the message arrived unencrypted through a VPN exit node rather than Microsoft's real mail infrastructure.
- Fear-based social engineering: an alarming 'unusual sign-in from Lagos, Nigeria' and a claim that access has already been 'temporarily limited' to provoke an immediate, panicked click.
- A tight 12-hour deadline is imposed to discourage the recipient from pausing to verify through official channels.
- The embedded link (login.micros0ft-online.com/secure/verify-identity) again uses the typo squatted domain rather than a real microsoft.com or live.com address.

From	Microsoft account team <security-noreply@micros0ft-online.com>
Reply-To	no-reply@micros0ft-online.com
Return-Path	bounce@micros0ft-online.com
To	aditya.rao@solveindustries.com
Cc	—
Bcc	—
Date & Time	10 July 2026, 2:03 AM IST
Received From	host-77-91-134-6.vpn-exit.net (77.91.134.6, unknown origin)
SPF	Fail
DKIM	Fail
DMARC	Fail
Encryption (TLS)	No

Exhibit 7a — Header snapshot. Sender domain is a typosquat (micros0ft-online.com — zero for 'o'); SPF/DKIM/DMARC all fail and the message routed through a VPN exit node.

EMAIL BODY

Microsoft account

We detected an unusual sign-in attempt on your account from a new device in Lagos, Nigeria on 10 July 2026 at 1:58 AM. If this wasn't you, your account may be compromised.

For your security, we have temporarily limited access to your account. To restore full access, please verify your identity within 12 hours by confirming your account details using the secure link below.

If you don't recognise this activity, we strongly recommend you review your account immediately to prevent unauthorized access to your email, OneDrive files and Teams messages.

Thanks,

The Microsoft account team

EMBEDDED LINK DETECTED

<https://login.microsoft-online.com/secure/verify-identity?ref=aditya.rao>

Exhibit 7b — Email body. Fear-based language ('unusual sign-in', 'temporarily limited') is highlighted alongside the fake verification link.

What Could Happen

The link leads to a fake Microsoft/Office 365 login page. Entering credentials there would hand the attacker Aditya's real corporate email/Microsoft 365 password (and potentially an MFA code if a fake prompt is included), giving them access to email, One Drive, and Teams — a common precursor to further BEC and data-theft attacks.

Recommended Action

Do not click the link. Verify any account-security concern by navigating directly to <https://account.microsoft.com> or the company's SSO portal (never via a link in the email). Report and delete the message, and if any credentials were ever entered on a similar page, reset the password immediately and check for unfamiliar mail-forwarding rules or app registrations.

Email 8 of 13 — Exciting Career Opportunity – Senior Finance Role (Immediate Response Needed)

Classification: **MEDIUM RISK**

From	Neha Kapoor, HR Consultant <neha.kapoor.hr@talentbridge-recruiters.net>
Reply-To	neha.kapoor.hr@talentbridge-recruiters.net
Return-Path	neha.kapoor.hr@talentbridge-recruiters.net
Received From	mail.talentbridge-recruiters.net (156.213.44.71, Singapore)
SPF	Pass (for talentbridge-recruiters.net)
DKIM	Pass
DMARC	None (no policy published)
Encryption (TLS)	Yes (TLS 1.2)

Reasoning / Evidence

- SPF and DKIM pass for the sender's own domain, so the email is not a forged Solvex address — the risk here is the content and intent of an otherwise 'authenticated' external sender, not header spoofing.
- No DMARC policy is published for the domain, which is common for newly-registered or disposable recruiting domains and offers no protection against others spoofing it in turn.
- Classic recruitment-scam / phishing-for-PII pattern: unsolicited approach, exaggerated offer ('40% higher than industry average'), false urgency ('close this week', 'reply within 24 hours'), and — critically — a request for a scanned PAN card and salary slip purely to 'shortlist' a candidate, which legitimate recruiters do not require this early.
- The attachment is a ZIP archive, a format very commonly used to smuggle executable malware past basic content filters (double extensions, macros, or password-protected payloads).

From	Neha Kapoor, HR Consultant <neha.kapoor.hr@talentbridge-recruiters.net> neha.kapoor.hr@talentbridge-recruiters.net
Reply-To	neha.kapoor.hr@talentbridge-recruiters.net
Return-Path	neha.kapoor.hr@talentbridge-recruiters.net
To	aditya.rao@solvexindustries.com
Cc	—
Bcc	—
Date & Time	10 July 2026, 11:20 AM IST
Received From	mail.talentbridge-recruiters.net (156.213.44.71, Singapore)
SPF	Pass (for talentbridge-recruiters.net)
DKIM	Pass
DMARC	None (no policy published)
Encryption	Yes (TLS 1.2)

Exhibit 8a — Header snapshot. SPF/DKIM pass for the sender's own domain, but no DMARC policy is published — offering no protection against lookalike abuse.

EMAIL BODY

Dear Candidate,

Your profile has been shortlisted for a Senior Finance Manager position with a leading MNC client of ours, offering a salary **40% higher** than industry average. We are impressed by your experience and would like to move forward quickly as the client wants to close this position this week.

Attached is the detailed Job Description along with the client company profile and compensation structure for your review. Please go through it and reply **within 24 hours** confirming your interest, along with a scanned copy of your latest salary slip and **PAN card** for our internal verification process.

Looking forward to your quick response so we can schedule your interview at the earliest.

Best regards,

Neha Kapoor

Senior HR Consultant, TalentBridge Recruiters

FILE JD_SeniorFinanceManager_Client.zip
ZIPArchive(compressed) • 2.4MB

Exhibit 8b — Email body. The request for a PAN card and salary slip, plus the ZIP attachment, are highlighted as the actual risk in this message

What Could Happen

Opening the ZIP could execute malware on Aditya's workstation (key loggers, remote-access Trojans). Separately, replying with a PAN card and salary slip would hand identity-fraud material — PAN number, salary, employer — to an unknown third party, which can be used for identity theft or further targeted social engineering against Solvex.

Recommended Action

Do not open the attachment. Do not send PAN card or salary details to unsolicited recruiters. Verify the recruiting firm's legitimacy independently (company registration, LinkedIn presence, phone verification) before any exchange of documents, and report the email to IT Security if received on a corporate mailbox.

Email 9 of 13 — Your Tally Prime Cloud Subscription Renewal Invoice – INV-88213

Classification: **SAFE**

From	Tally Solutions Billing <billing@tallysolutions.com>
Reply-To	billing@tallysolutions.com
Return-Path	billing@tallysolutions.com
Received From	mta-out.tallysolutions.com (203.0.113.44)
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.3)

Reasoning / Evidence

- Sender, Reply-To and Return-Path all consistently use the genuine tallysolutions.com domain, and SPF/DKIM/DMARC all pass.
- Explicitly states 'no bank details have changed' and directs payment to the existing registered method / bank on file — the opposite pattern of the fraud seen in Email 3.
- No urgency tactics, no threats, and the Cc to the internal accounts@solvexindustries.com mailbox are consistent with a routine, expected renewal notice.
- Attachment is a standard PDF invoice, a low-risk format compared to macro-enabled documents or executables.

From	Tally Solutions Billing <billing@tallysolutions.com>
Reply-To	billing@tallysolutions.com
Return-Path	billing@tallysolutions.com
To	aditya.rao@solvexindustries.com
Cc	accounts@solvexindustries.com
Bcc	—
Date & Time	11 July 2026, 10:00 AM IST
Received From	mta-out.tallysolutions.com (203.0.113.44)
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.3)

Exhibit 9 — Header snapshot. Consistent genuine vendor domain across all fields; SPF, DKIM, and DMARC all pass; no bank-detail change requested.

Assessment

No malicious outcome expected from this email as written.

Recommended Action

Process as a normal renewal through existing , previously verified payment channels. As routine hygiene, confirm the license ID and amount match prior invoices before payment.

Email 10 of 13 — CONGRATULATIONS!!! YOU HAVE WON USD 1,000,000 IN THE INTERNATIONAL EMAIL LOTTERY

Classification: **SUSPICIOUS**

From	INTERNATIONAL LOTTERY BOARD <claims.department009@yandex-mailer.com>
Reply-To	agent.williams.claims@outlook-verify.info
Return-Path	claims.department009@yandex-mailer.com
Received From	unknown-relay-node4.freehosting-mail.com (185.220.101.44, Netherlands)
SPF	Fail
DKIM	Fail
DMARC	Fail
Encryption (TLS)	No

Reasoning / Evidence

- Sent to 'undisclosed-recipients' and Bcc'd to Aditya — a mass, untargeted blast rather than a genuine personal notification.
- SPF, DKIM and DMARC all fail; the message routes through an anonymous, unencrypted free hosting relay with no connection to any real lottery authority.
- Textbook advance-fee ('419') fraud: an implausible unsolicited windfall, invented authority ('European Lottery Commission'), and a request for personal ID plus a small 'processing/courier fee' — the classic mechanism by which the scam actually extracts money.
- Artificial urgency (48-hour deadline, prize forfeiture threat) to prevent the recipient from thinking it through or researching the scam.

From	INTERNATIONAL LOTTERY BOARD <claims.department009@yandex-mailer.com>
Reply-To	agent.williams.claims@outlook-verify.info
Return-Path	claims.department009@yandex-mailer.com
To	undisclosed-recipients
Cc	—
Bcc	aditya.rao@solvexindustries.com
Date & Time	11 July 2026, 4:52 PM IST
Received From	unknown-relay-node4.freehosting-mail.com (185.220.101.44, Netherlands)
SPF	Fail
DKIM	Fail
DMARC	Fail
Encryption (TLS)	No

Exhibit 10a — Header snapshot. Reply-To routes to a third, unrelated domain; SPF/DKIM/DMARC all fail; message Bcc'd to 'undisclosed recipients'.

EMAIL BODY

ATTENTION WINNER,

We are pleased to inform you that your email address has WON the sum of USD 1,000,000.00 (One Million US Dollars Only) in the International Email Lottery Programme 2026, held under the supervision of the European Lottery Commission.

To claim your prize, you are required to contact our Claims Agent immediately with your full name, address, phone number, and a **copy of your ID for verification**. A small processing and **courier fee of USD 250** will be required to release your winning certificate and cheque.

Please respond within 48 hours failure of which your prize will be forfeited and awarded to another participant.

Congratulations once again!

Dr. James Williams, Claims Coordinator

EMBEDDED LINK DETECTED

<hxyp://claim-your-prize-now.lottery-verify.info/claim?ref=44921>

***Exhibit 10b** — Email body. The advance-fee request ('processing and courier fee') and ID request are highlighted — the actual mechanism by which this scam extracts money.*

What Could Happen

Paying the 'processing fee' results in direct financial loss with no prize ever delivered, and further fee requests typically follow. Submitting ID documents and personal details also exposes the victim to identity theft.

Recommended Action

Do not respond, pay any fee, or send identification documents. Delete and report as spam/phishing; no legitimate lottery requires a winner to pay to receive winnings.

Email 11 of 13 — Quick request before my flight

Classification: **SUSPICIOUS**

From	Suresh Iyer (CFO) <suresh.iyer@solvexindustries.com>
Reply-To	s.iyer.cfo.travel@outlook.com
Return-Path	suresh.iyer@solvexindustries.com
Received From	mail.solvexindustries.com (192.168.14.19) — internal relay shown, but Reply-To routes externally
SPF	Pass (envelope sender matches solvexindustries.com)
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.3)

Reasoning / Evidence

- Although SPF/DKIM/DMARC pass and the visible From address looks internal, the Reply-To (s.iyer.cfo.travel@outlook.com) silently redirects any reply to a free, unrelated Outlook address — the recipient would never notice this unless they check headers, since most mail clients only show the display name when replying.
- This mismatch is consistent either with a spoofed display name riding on a technically-passing envelope, or a compromised/impersonated internal account paired with an external reply channel — both are red flags regardless of which is true.
- Classic gift-card BEC social engineering: authority (CFO), a plausible cover story (card not working, boarding a flight), extreme urgency (20 minutes), and an explicit instruction to avoid verification channel ('don't call the office landline').
- Requests an unusual and easily-monetized payment mechanism (gift card codes sent by email) — no real corporate reimbursement process works this way.

From	Suresh Iyer (CFO) <suresh.iyer@solvexindustries.com>
Reply-To	s.iyer.cfo.travel@outlook.com
Return-Path	suresh.iyer@solvexindustries.com
To	aditya.rao@solvexindustries.com
Cc	—
Bcc	—
Date & Time	12 July 2026, 8:31 AM IST
Received From	mail.solvexindustries.com (192.168.14.19) — header shows internal relay, but Reply-To routes externally
SPF	Pass (envelope sender matches solvexindustries.com)
DKIM	Pass
DMARC	Pass
Encryption	Yes (TLS 1.3)

Exhibit 11a — Header snapshot. Reply-To silently routes to an outlook.com address, not solvexindustries.com, even though SPF/DKIM/DMARC pass on the envelope.

EMAIL BODY

Aditya,

About to board my flight to Mumbai and my corporate card isn't working at the airport lounge. Can you do me a favour and buy 5 Amazon gift cards of Rs. 5,000 each from the online store, then send me the card codes here — I'll reimburse you as soon as I land. Need it in the next 20 minutes before boarding closes.

Please don't call the office landline about this, my phone network is patchy while boarding, email is easier to check. Really appreciate this, will make it up to you.

Suresh

Exhibit 11b — Email body. The instruction to avoid calling the office landline and the gift-card request are highlighted as the actual fraud mechanism.

What Could Happen

If Aditya purchased the gift cards and sent the codes, the funds (Rs. 25,000) would be immediately redeemed by the attacker and are effectively unrecoverable, since gift card codes cannot be traced or reversed once redeemed.

Recommended Action

Do not purchase gift cards or send codes. Verify by calling Suresh Iyer directly on his known mobile number (not the Reply-To address) before acting. Report the email to IT Security — the Reply-To mismatch on an otherwise 'internal-looking' message should be escalated as a possible account compromise or spoofing incident and used as a training example.

Email 12 of 13 — Reminder: Mandatory Security Awareness Training – Due This Friday**Classification: SAFE**

From	Information Security Team – Solvex Industries <infosec@solvexindustries.com>
Reply-To	infosec@solvexindustries.com
Return-Path	infosec@solvexindustries.com
Received From	mail.solvexindustries.com (192.168.14.19) – internal mail server
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.3)

Reasoning / Evidence

- Fully consistent internal sender, Reply-To and Return-Path; SPF/DKIM/DMARC all pass over an encrypted internal connection.
- Directs staff to the internal learn.solvexindustries.com portal by employee ID login rather than an external or embedded credential-harvesting link.
- Content and tone (mandatory training reminder, reasonable deadline, help via the official IT Helpdesk portal) match normal internal security operations communication.

From	Information Security Team – Solvex Industries <infosec@solvexindustries.com>
Reply-To	infosec@solvexindustries.com
Return-Path	infosec@solvexindustries.com
To	all-employees@solvexindustries.com
Cc	—
Bcc	—
Date & Time	12 July 2026, 9:15 AM IST
Received From	mail.solvexindustries.com (192.168.14.19)
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption (TLS)	Yes (TLS 1.3)

Exhibit 12a — Header snapshot. Consistent internal InfoSec sender; SPF, DKIM, and DMARC all pass.

EMAIL BODY

Dear Colleague,

This is a reminder that the mandatory Q3 Security Awareness Training module, covering phishing identification, password hygiene and safe attachment handling, must be completed on the internal Learning Portal by this Friday, 17 July 2026.

As highlighted in recent incidents across the industry, email-based fraud continues to be one of the top risks to organisations. This training will take approximately 25 minutes to complete and includes a short assessment at the end.

To access the module, log in to learn.solvexindustries.com using your employee ID. If you experience any login issues, please raise a request with the IT Helpdesk through the official portal.

Regards,

Information Security Team

Solvex Industries Pvt. Ltd.

Exhibit 12b — Email body. Directs staff to the internal learning portal (learn.solvexindustries.com) by employee ID — no external or credential-harvesting link.

Assessment

No malicious outcome expected from this email as written.

Recommended Action

No action required beyond completing the training as instructed via the known internal portal.

Email 13 of 13 — Pending Invoice – Please Review & Process on Priority**Classification: SUSPICIOUS**

From	Accounts Receivable <accounts.receivable@shreeganesh-logistics.in>
Reply-To	accounts.receivable@shreeganesh-logistics.in
Return-Path	mailer@shreeganesh-logistics.in
Received From	webmail-host-4.sharedhosting-cluster.com (41.203.88.17) — unrelated shared hosting cluster, not shreeganesh-logistics.in infrastructure
SPF	Fail (domain not authorized to send)
DKIM	None
DMARC	Fail
Encryption (TLS)	No

Reasoning / Evidence

- SPF explicitly fails as 'domain not authorized to send', DKIM is absent, and DMARC fails — the message did not actually originate from Shree Ganesh Logistics' own mail servers despite the display name, and instead came from an unrelated shared hosting cluster.
- The attachment is a macro-enabled Word document (.docm) — a well-known malware delivery format — and the email explicitly instructs the recipient to 'enable editing/macros if prompted', which is precisely the social-engineering step required to let a malicious macro execute.
- Combines mild urgency (accounts overdue for closing) with a routine-sounding business pretext (transport invoice, delivery challans) to lower the recipient's guard before the macro instruction.
- The embedded link domain (shreeganesh-logistics.in.invoice-view-secure.com) is crafted to visually incorporate the real vendor's domain name as a subdomain-style prefix of an unrelated domain — a common lookalike technique.

From	Accounts Receivable <accounts.receivable@shreeganesh-logistics.in>
Reply-To	accounts.receivable@shreeganesh-logistics.in
Return-Path	mailer@shreeganesh-logistics.in
To	aditya.rao@solvexindustries.com
Cc	—
Bcc	—
Date & Time	13 July 2026, 5:58 PM IST
Received From	webmail-host-4.sharedhosting-cluster.com (41.203.88.17, unrelated hosting cluster)
SPF	Fail (domain not authorised to send)
DKIM	None
DMARC	Fail
Encryption	No

Exhibit 13a — Header snapshot. SPF fails ('domain not authorised to send'), no DKIM, DMARC fails; the message originated from an unrelated shared hosting cluster, not the vendor's real domain.

EMAIL BODY

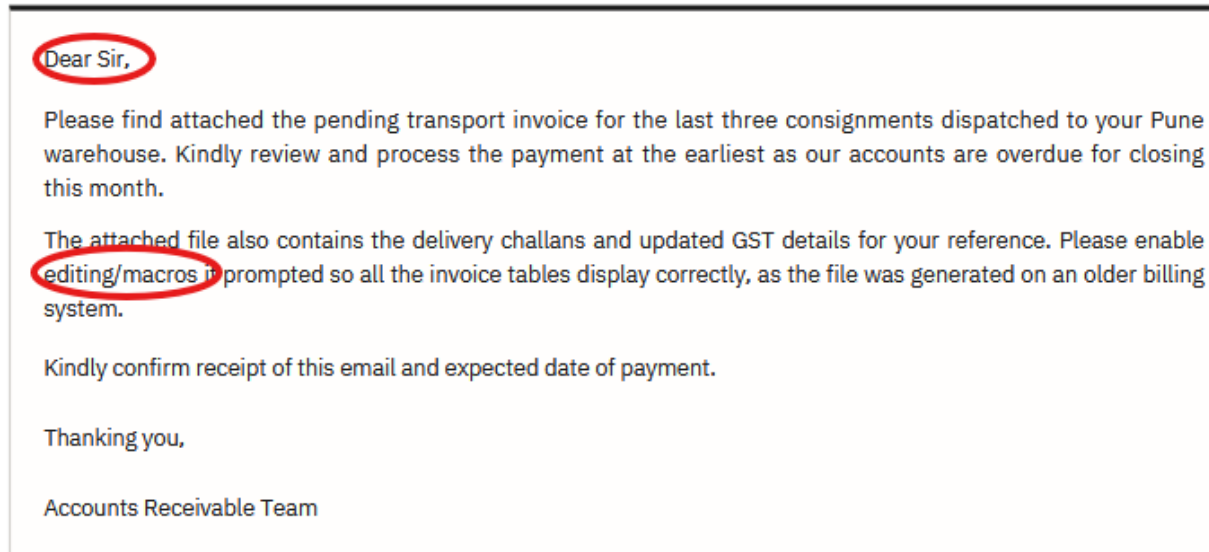


Exhibit 13b — Email body. The instruction to ‘enable editing/macros’ is highlighted — this is precisely the step required for the malicious macro payload to execute.

What Could Happen

Enabling macros in the attached .docm would very likely execute a malicious macro payload, potentially installing malware (Trojan, ransom ware, or a credential-stealing loader) on Aditya's machine and providing the attacker a foothold on the Solvex network.

Recommended Action

Do not enable editing or macros. Do not click the embedded link. Verify the invoice with Shree Ganesh Logistics via a known phone number before opening any attachment. Submit the file to IT Security / sandbox analysis rather than opening it locally, and block the sending infrastructure and link domain at the email gateway.

Indicators of Compromise (IOCs)

The following domains, IP addresses, links, and attachments were identified as malicious or suspicious across the 13 emails reviewed. These should be blocked at the email gateway / web proxy and used to search other mailboxes for related compromise.

Suspicious / Spoofed Domains

Email #	Malicious / Suspicious Domain	Notes
2	solvex-industries-helpdesk.com	Credential phishing (IT Helpdesk spoof)
2	mail-secure-verify.net	Credential phishing (IT Helpdesk spoof)
2	solvex-industries-helpdesk.verify-account-secure.com	Credential phishing (IT Helpdesk spoof)
3	apexsteel-billing.com (mismatched Reply-To)	Vendor payment redirection (BEC)
5	gmail-corpmail.com	CEO fraud / wire-transfer BEC
5	freemailhost.io	CEO fraud / wire-transfer BEC
7	microsoft-online.com	Credential phishing (Microsoft spoof)
8	talentbridge-recruiters.net	Recruitment scam / PII & malware
10	yandex-mailer.com	Advance-fee lottery scam
10	outlook-verify.info	Advance-fee lottery scam
10	lottery-verify.info	Advance-fee lottery scam
10	freehosting-mail.com	Advance-fee lottery scam
11	outlook.com (mismatched Reply-To for a claimed CFO)	Gift-card BEC scam
13	shreeganesh-logistics.in.invoice-view-secure.com	Malware delivery (macro document)

Suspicious Originating IP Addresses / Infrastructure

Email #	Suspicious IP / Infrastructure
2	193.41.77.108
5	45.137.22.9
7	77.91.134.6
8	156.213.44.71
10	185.220.101.44
13	41.203.88.17

Malicious Links (defanged)

Email #	Malicious Link (defanged)
2	hxxp://solvex-industries-helpdesk.verify-account-secure.com/mailbox/confirm?user=aditya.rao
7	hxxp://login.microsoft-online.com/secure/verify-identity?ref=aditya.rao
10	hxxp://claim-your-prize-now.lottery-verify.info/claim?ref=44921
13	hxxp://shreeganesh-logistics.in.invoice-view-secure.com/download?file=inv2207

Malicious / High-Risk Attachments

Email #	Suspicious Attachment	Risk
8	JD_SeniorFinanceManager_Client.zip	Recruitment scam / PII & malware
13	Pending_Invoice_Challan_Details.docm (macro-enabled)	Malware delivery (macro document)

Recommended Actions

Per-Email Actions (Suspicious / Medium Risk)

Email #	Subject	Recommended Action
2	URGENT: Your Mailbox Storage is FULL – Verify Now to Avoid Suspension	Do not click the link or enter credentials. Report the email to IT Security as phishing, delete it, and if credentials were ever entered on a similar past email, force an immediate password reset and check mailbox forwarding/rules for tampering. Block the sending domain and originating IP at the email gateway.
3	Invoice SI-4471 & Updated Bank Details for Future Payments	Do NOT update payment details based on this email alone. Call Apex Steel Traders on a previously known, independently verified phone number (not one provided in this email) to confirm the bank account change verbally. Compare the Reply-To domain against past correspondence with this vendor. Escalate to finance leadership and treat as a possible vendor account compromise until confirmed otherwise.
5	Confidential – Immediate Wire Transfer Required (Time Sensitive)	Do not reply or act on the request. Independently verify by calling Rajeev Malhotra on his known company mobile number (not any number in the email) or confirming in person/via a separate verified channel. Report to IT Security and Finance leadership immediately, and remind staff that no genuine executive request will ask to bypass Accounts or normal approval workflow.
7	Unusual sign-in activity detected on your Microsoft account	Do not click the link. Verify any account-security concern by navigating directly to https://account.microsoft.com or the company's SSO portal (never via a link in the email). Report and delete the message, and if any credentials were ever entered on a similar page, reset the password immediately and check for unfamiliar mail-forwarding rules or app registrations.
8	Exciting Career Opportunity – Senior Finance Role (Immediate Response Needed)	Do not open the attachment. Do not send PAN card or salary details to unsolicited recruiters. Verify the recruiting firm's legitimacy independently (company registration, LinkedIn presence, phone verification) before any exchange of documents, and report the email to IT Security if received on a corporate mailbox.
10	CONGRATULATIONS!!! YOU HAVE WON USD 1,000,000 IN THE INTERNATIONAL EMAIL LOTTERY	Do not respond, pay any fee, or send identification documents. Delete and report as spam/phishing; no legitimate lottery requires a winner to pay to receive winnings.
11	Quick request before my flight	Do not purchase gift cards or send codes. Verify by calling Suresh Iyer directly on his known mobile number (not the Reply-To address) before acting. Report the email to IT Security — the Reply-To mismatch on an otherwise 'internal-looking' message should be escalated as a possible account compromise or spoofing incident and used as a training example.
13	Pending Invoice – Please Review & Process on Priority	Do not enable editing or macros. Do not click the embedded link. Verify the invoice with Shree Ganesh Logistics via a known phone number before opening any attachment. Submit the file to IT

		Security / sandbox analysis rather than opening it locally, and block the sending infrastructure and link domain at the email gateway.
--	--	--

Organization-Wide Recommendations

- Implement mandatory out-of-band verification (phone call to a previously known number) for any request involving a wire transfer, bank-account change, or gift-card purchase, regardless of who it appears to be from.
- Enforce a strict DMARC 'reject' policy (not just 'monitor') at the email gateway, and ensure no policy overrides are permitted for external mail claiming to be from internal or partner domains.
- Block the identified typo squatted and lookalike domains, associated IPs, and links at the email security gateway and web proxy across the organization.
- Disable macro execution by default for documents received from outside the organization, or route such attachments through a sandbox before delivery.
- Re-brief the finance team specifically on vendor bank-detail-change fraud and BEC/gift-card scams, using Emails 3, 5, and 11 from this case as real, de-identified training examples.
- Confirm with Apex Steel Traders (Email 3) and Shree Ganesh Logistics (Email 13) directly, via known contact numbers, whether either has experienced a mailbox compromise, since these emails may originate from breached vendor accounts rather than pure spoofing.
- Review mail flow rules and forwarding settings on Aditya Rao's mailbox for any signs that credentials were already compromised prior to this investigation.